

Informe de Seguridad Ruta Cinépolis

Metodología: SAST mediante análisis estático de código fuente, SCA mediante npm audit, e inspección de configuraciones de seguridad en tiempo de ejecución.

Estándar de referencia: OWASP Top 10 (2021)

1. Resumen de hallazgos

El análisis de seguridad identificó un total de 26 vulnerabilidades distribuidas entre los componentes backend y frontend del sistema. Ninguna de ellas es de severidad crítica. Las vulnerabilidades de mayor impacto corresponden a dependencias desactualizadas, nodemailer en el backend y vite en el frontend. La configuración de seguridad base del sistema (Helmet, CORS, JWT, rate limiting, validación con Zod) se encuentra correctamente implementada.

Severidad	Backend	Frontend	Total
Crítica	0	0	0
Alta	2	2	4
Moderada	21	1	22
Baja	0	0	0
Total	23	3	26

2. Hallazgos por Componente

2.1 Backend - Dependencias Vulnerables (SCA)

VUL-001- nodemailer: Denegación de servicio por recursión en el parser de direcciones

Campo	Detalle
Severidad	Alta
CVSS	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:H)
CWE	CWE-703
Paquete afectado	nodemailer <= 7.0.10
Referencia	GHSA-rcmh-qjqh-p98v
Descripción	El parser de direcciones de correo electrónico en Nodemailer es vulnerable a un ataque de Denegación de Servicio (DoS) provocado por llamadas recursivas al procesar direcciones

	maliciosamente formadas. Un atacante sin autenticación puede bloquear el procesamiento de correos del servidor.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL-002 - nodemailer: SSRF y lectura arbitraria de archivos mediante opción raw

Campo	Detalle
Severidad	Alta
CVSS	7.1 (AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N)
CWE	CWE-73, CWE-918
Paquete afectado	nodemailer <= 9.0.0
Referencia	GHSA-p6gq-j5cr-w38f
Descripción	La opción raw a nivel de mensaje omite las restricciones disableFileAccess y disableUrlAccess durante la normalización del mensaje. Esto permite a un atacante autenticado leer archivos arbitrarios del sistema o realizar solicitudes SSRF (Server-Side Request Forgery) a recursos internos.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL- 003 - nodemailer: Envío de correo a dominio no intencionado

Campo	Detalle
Severidad	Moderada
CWE	CWE-20, CWE-436
Paquete afectado	nodemailer < 7.0.7
Referencia	GHSA-mm7p-fcc7-pg87
Descripción	Debido a un conflicto de interpretación en el parser, el correo puede ser enviado a un dominio no intencionado cuando el campo destinatario contiene caracteres especiales o codificaciones ambiguas.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL-004 - nodemailer: Inyección de comandos SMTP mediante CRLF en el nombre del transport (EHLO/HELO)

Campo	Detalle
Severidad	Alta
CVSS	4.9 (AV:N/AC:L/PR:H/UI:N/S:U/C:N/I:H/A:N)
CWE	CWE-93
Paquete afectado	nodemailer <= 8.0.4
Referencia	GHSA-vvjj-xcjj-gr5g
Descripción	La opción name del transport no sanitiza correctamente los caracteres CRLF, lo que permite a un administrador con acceso a la configuración inyectar comandos SMTP arbitrarios en el saludo EHLO/HELO.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL - 005 - nodemailer: Inyección en cabeceras List-* mediante CRLF

Campo	Detalle
Severidad	Moderada
CVSS	5.4 (AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N)
CWE	CWE-93
Paquete afectado	nodemailer <= 8.0.8
Referencia	GHSA-268h-hp4c-crj3
Descripción	Los comentarios de las cabeceras List-* no son sanitizados, permitiendo la inyección de cabeceras de mensaje arbitrarias mediante secuencias CRLF.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL - 006 - nodemailes: json Transport omite restricciones de acceso a archivos y URLs.

Campo	Detalle
Severidad	Moderada
CVSS	5.4 (AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N)

CWE	CWE-862
Paquete afectado	nodemailer <= 8.0.8
Referencia	GHSA-wqvq-jvpq-h66f
Descripción	El transport jsonTransport no aplica las restricciones disableFileAccess y disableUrlAccess durante la normalización del mensaje.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL- 007 - nodemailer: Validación TLS incorrecta en la obtención de tokens OAuth2

Campo	Detalle
Severidad	Moderada
CVSS	6.5 (AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:L/A:N)
CWE	CWE-195
Paquete afectado	nodemailer <= 8.0.7
Referencia	GHSA-r7g4-qg5f-qqm2
Descripción	La validación del certificado TLS es incorrecta al realizar solicitudes de tokens OAuth2, lo que hace posible la interceptación de credenciales mediante un ataque de tipo Man-in-the-Middle.
Corrección	Actualizar a nodemailer >= 9.0.1

VUL - 008 - uuid: Escritura fuera de límites de buffer en v3/v5/v6

Campo	Detalle
Severidad	Moderada
CVSS	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:N)
CWE	CWE-787, CWE-1285
Paquete afectado	uuid < 11.1.1
Referencia	GHSA-w5hq-g745-h8pq
Descripción	Cuando se provee el parámetro buf a las funciones v3, v5 o

	v6 sin validar sus límites, se puede producir una escritura fuera del rango del buffer asignado, lo que puede resultar en corrupción de memoria o comportamientos indefinidos.
Corrección	Actualizar a uuid >= 11.1.1

VUL - 009 - joi: RangeError no capturado en schemas link() recursivos

Campo	Detalle
Severidad	Moderada
CVSS	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-248, CWE-400
Paquete afectado	joi < 17.13.4
Referencia	GHSA-q7cg-457f-vx79
Descripción	Entradas profundamente anidadas procesadas a través de schemas link() recursivos de Joi desencadenan un RangeError no capturado que puede causar la terminación del proceso Node.js.
Corrección	Actualizar a joi >= 17.13.4

VUL - 010 -js-yaml: DoS de complejidad cuadrática en claves de fusión con alias repetidos

Campo	Detalle
Severidad	Moderada
CVSS	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-407
Paquete afectado	js-yaml <= 4.1.1 (dependencia de @istanbuljs/load-nyc-config, herramienta de desarrollo)
Referencia	GHSA-h67p-54hq-rp68
Descripción	El manejo de claves de fusión YAML con alias repetidos tiene complejidad cuadrática, permitiendo ataques de DoS mediante archivos YAML especialmente contruidos. Afecta únicamente al entorno de pruebas.

Corrección	Actualizar ts-jest a versión mayor $\geq 27.0.3$ (requiere evaluar compatibilidad)
------------	--

2.1 FrontEnd - Dependencias Vulnerables (SCA)

VUL-011 - vite: Bypass de restricciones del servidor de desarrollo mediante

Campo	Detalle
Severidad	Alta
CVSS	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-200
Paquete afectado	vite $< 6.0.9$
Referencia	GHSA-x574-m823-4x7w
Descripción	Un atacante puede acceder a archivos fuera de los directorios permitidos cuando el servidor de desarrollo está expuesto a una red y utiliza configuraciones específicas de <code>server.fs.deny</code> . Esto puede provocar divulgación de información sensible durante el desarrollo. .
Corrección	Actualizar a vite $\geq 6.0.9$)

VUL-012 - vite: Exposición de archivos arbitrarios mediante bypass de control de acceso

Campo	Detalle
Severidad	Alta
CVSS	7.5 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-22
Paquete afectado	vite $< 6.0.12$
Referencia	GHSA-859w-5945-r5v3
Descripción	

	El servidor de desarrollo de Vite permite acceder a archivos que deberían encontrarse restringidos bajo determinadas condiciones de configuración, permitiendo la lectura de información sensible en entornos de desarrollo.
Corrección	Actualizar a vite >= 6.0.12)

VUL-013 - vite: Cross-Site WebSocket Hijacking (CSWSH) en HMR

Campo	Detalle
Severidad	Moderada
CVSS	5.3 (AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:N/A:L)
CWE	CWE-1385
Paquete afectado	vite < 6.0.9
Referencia	GHSA-vg6x-rcgg-rjx6
Descripción	El mecanismo Hot Module Replacement (HMR) del servidor de desarrollo no valida adecuadamente el origen de las conexiones WebSocket. Un sitio malicioso podría establecer conexiones no autorizadas al servidor de desarrollo y acceder a información del entorno local del desarrollador .
Corrección	Actualizar a vite >= 6.0.12)